



FUNDAMENTALS OF INFORMATION SYSTEM SECURITY

SEC285 Final Course Project

July 2024

Barbara Espericueta

Prof. Christina Bailey

INTRODUCTION

01

OVERALL PROJECT: THIS COURSE PROJECT COVERS THE FUNDAMENTALS OF INFORMATION SECURITY ATTACKS AND DEFENSE MECHANISMS. SECURITY ISSUES RELATED TO PEOPLE, DATA, NETWORKS, AND DEVICES ARE SURVEYED TO PROVIDE INSIGHT INTO DESIGNING SECURITY SOLUTIONS AND POLICIES.

02

OBJECTIVE: EXPLORING TECHNOLOGIES AND PRACTICES THAT SUPPORT THE SECURITY PRINCIPLES OF CONFIDENTIALITY, INTEGRITY, AND AVAILABILITY.

03

TOOLS: ACI LEARNING INFOSEC LEARNING INC, GOOGLE, LIVE DEVRY STUDY, LINUX VM, KALI VM, MICROSOFT WORD.

SEC285
MODULE 2
ASYMMETRIC KEY
ENCRYPTION

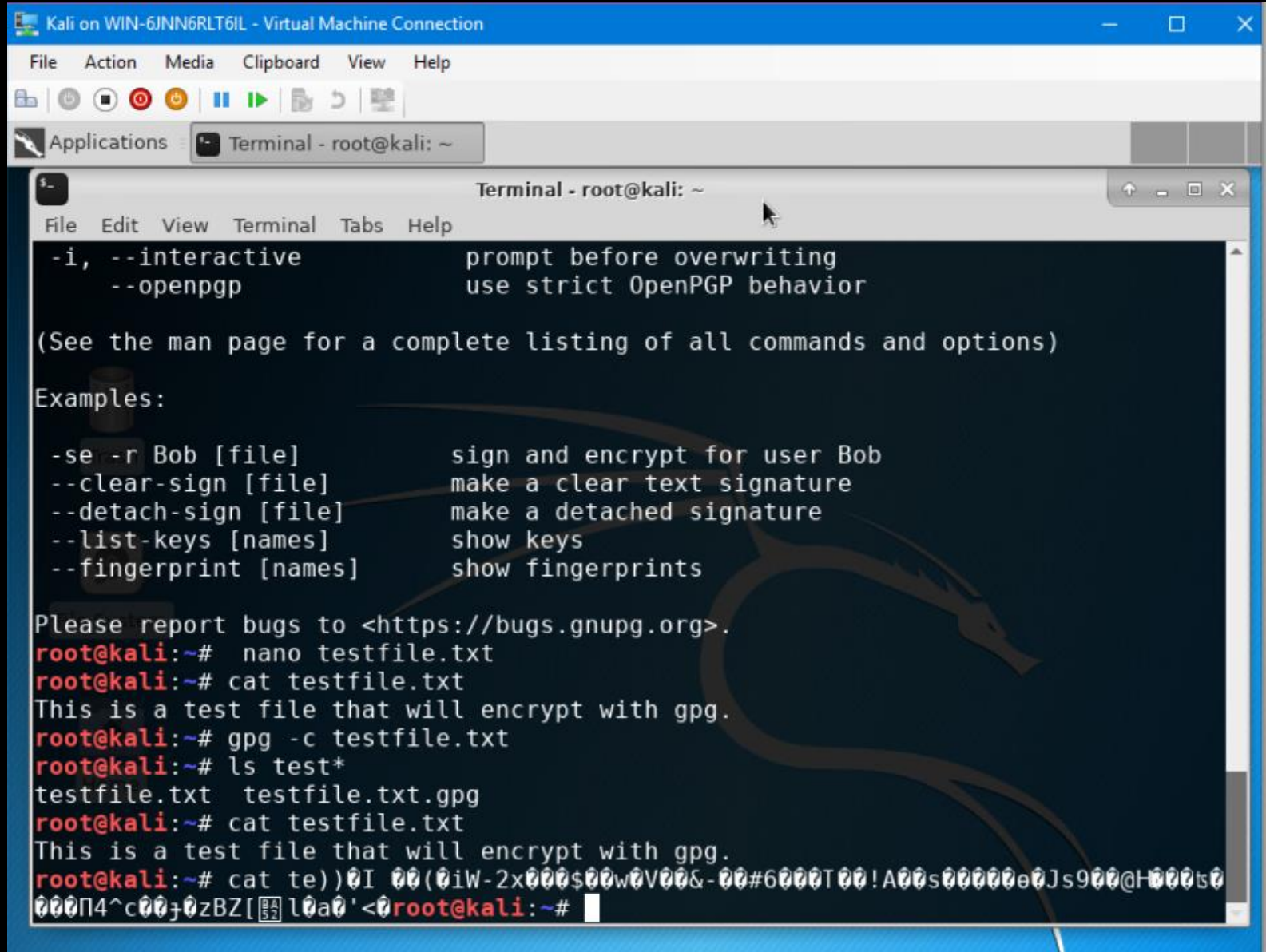
INTRODUCTION

In this module, we explore technical and administrative controls using encryption. Secure file management is implemented to mitigate risks to enterprise data assets.

FILE ENCRYPTION

This screenshot shows the following.

- Content of the plaintext file
- Content of the encrypted file



```
Kali on WIN-6JNN6RLT6IL - Virtual Machine Connection
File Action Media Clipboard View Help
Applications Terminal - root@kali: ~

Terminal - root@kali: ~
File Edit View Terminal Tabs Help

-i, --interactive          prompt before overwriting
--openpgp                  use strict OpenPGP behavior

(See the man page for a complete listing of all commands and options)

Examples:

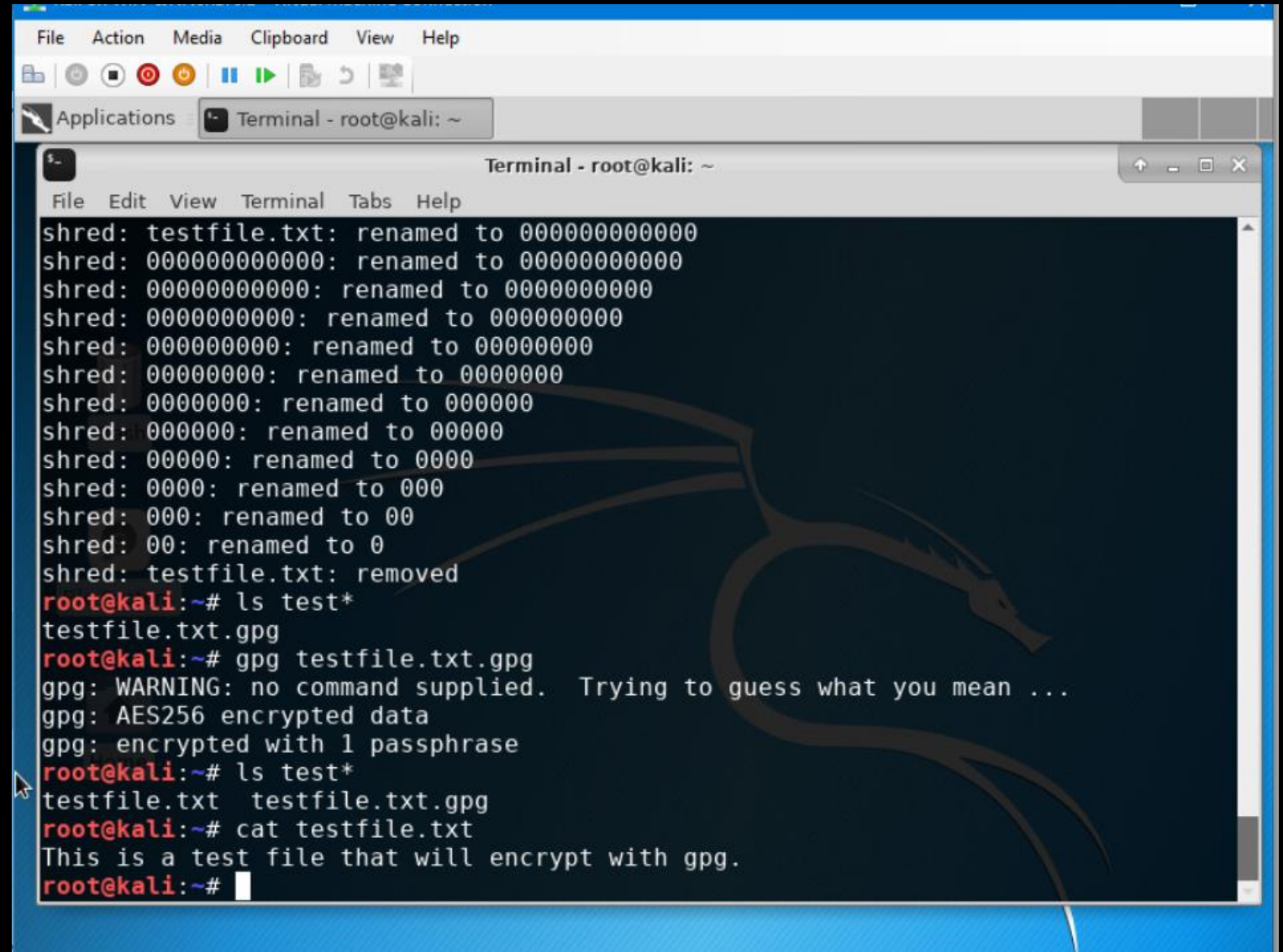
-se -r Bob [file]          sign and encrypt for user Bob
--clear-sign [file]        make a clear text signature
--detach-sign [file]       make a detached signature
--list-keys [names]        show keys
--fingerprint [names]     show fingerprints

Please report bugs to <https://bugs.gnupg.org>.
root@kali:~# nano testfile.txt
root@kali:~# cat testfile.txt
This is a test file that will encrypt with gpg.
root@kali:~# gpg -c testfile.txt
root@kali:~# ls test*
testfile.txt  testfile.txt.gpg
root@kali:~# cat testfile.txt
This is a test file that will encrypt with gpg.
root@kali:~# cat te))0I 00(0iW-2x000$00w0V00&-00#6000T00!A00s00000e0Js900@H000t0
000P4^c00j0zBZ[0A]l0a0'<0root@kali:~#
```

FILE DECRYPTION

This screenshot shows the following.

- The encrypted file being listed by itself
- The decrypting process
- Both the encrypted file and the original plaintext file being listed



```
File Action Media Clipboard View Help
Applications Terminal - root@kali: ~

Terminal - root@kali: ~
File Edit View Terminal Tabs Help
shred: testfile.txt: renamed to 000000000000
shred: 000000000000: renamed to 000000000000
shred: 000000000000: renamed to 000000000000
shred: 00000000000: renamed to 000000000000
shred: 0000000000: renamed to 0000000000
shred: 000000000: renamed to 00000000
shred: 00000000: renamed to 0000000
shred: 0000000: renamed to 000000
shred: 000000: renamed to 00000
shred: 00000: renamed to 0000
shred: 0000: renamed to 000
shred: 000: renamed to 00
shred: 00: renamed to 0
shred: testfile.txt: removed
root@kali:~# ls test*
testfile.txt.gpg
root@kali:~# gpg testfile.txt.gpg
gpg: WARNING: no command supplied. Trying to guess what you mean ...
gpg: AES256 encrypted data
gpg: encrypted with 1 passphrase
root@kali:~# ls test*
testfile.txt testfile.txt.gpg
root@kali:~# cat testfile.txt
This is a test file that will encrypt with gpg.
root@kali:~#
```

CONCLUSION

A variety of best practices are employed by Linux administrators to address security vulnerabilities, including disabling unnecessary services, improving logging and network time management, implementing a package management system, encrypting data at rest and in transit, enforcing logging activities, and implementing security controls to prevent dictionary attacks and brute force attacks.

SEC285
MODULE 3
STATEFUL
FIREWALL

INTRODUCTION

In this module, firewalls are introduced and their use in protecting enterprise computing resources is explained.

QUESTION

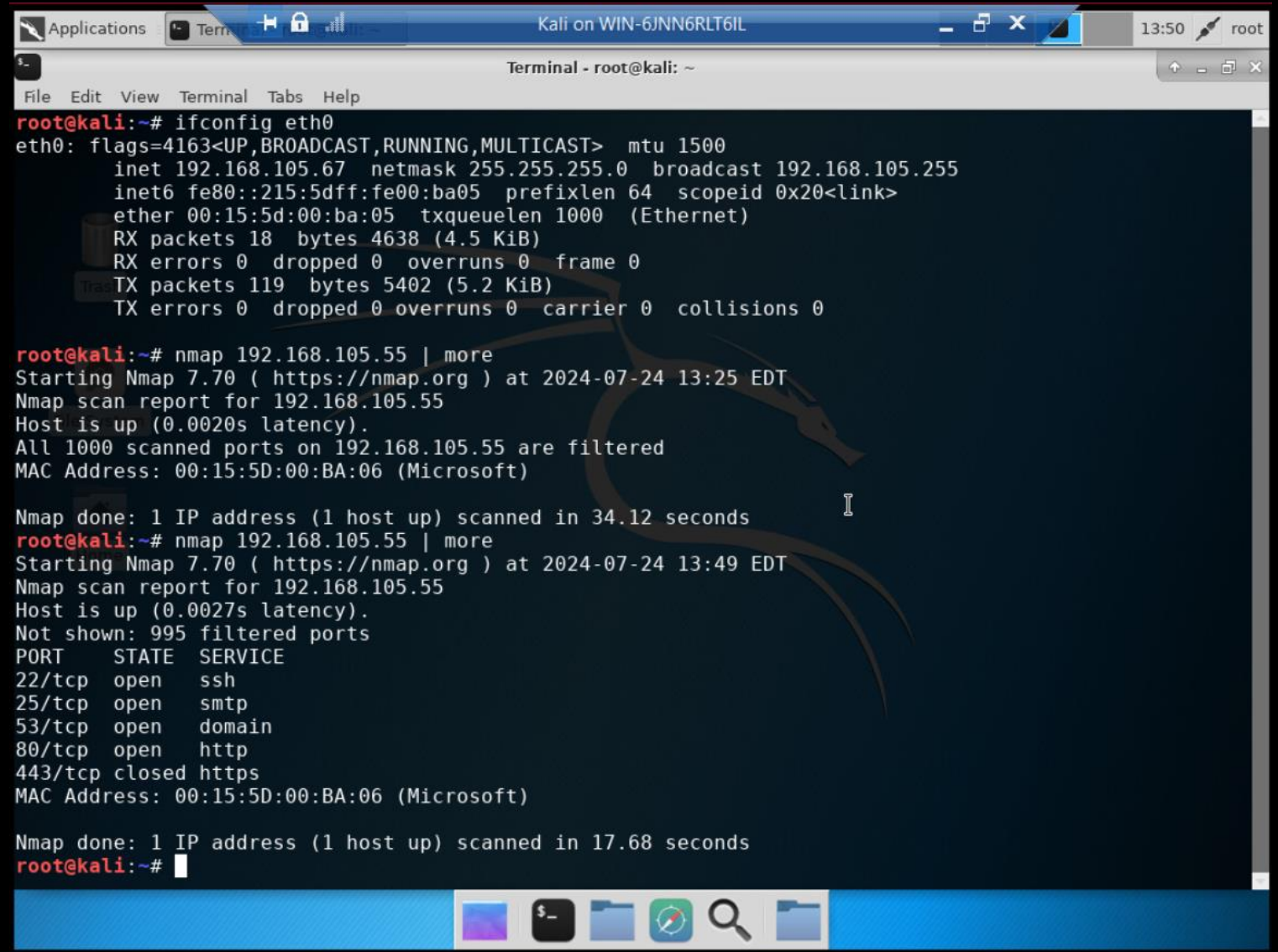
What effect does the `sudo iptables --policy INPUT DROP` command have on the access to computing resources?

Answer: `sudo iptables --policy INPUT DROP` command adds a rule to our policy section specifically for incoming traffic. For incoming and outgoing network traffic, iptables configures Linux kernel firewall rules, allowing regulations to determine which packets can be allowed to pass and which should be rejected.

References: aci learning, INFOSEC LEARNING INC

NMAP SCAN

This screenshot shows the
Nmap scan result of the
Linux Server VM.



The screenshot shows a Kali Linux terminal window with the following content:

```
Applications Terminal Kali on WIN-6JNN6RLT6IL 13:50 root
Terminal - root@kali: ~
File Edit View Terminal Tabs Help
root@kali:~# ifconfig eth0
eth0: flags=4163<UP,BROADCAST,RUNNING,MULTICAST> mtu 1500
    inet 192.168.105.67 netmask 255.255.255.0 broadcast 192.168.105.255
    inet6 fe80::215:5dff:fe00:ba05 prefixlen 64 scopeid 0x20<link>
    ether 00:15:5d:00:ba:05 txqueuelen 1000 (Ethernet)
    RX packets 18 bytes 4638 (4.5 KiB)
    RX errors 0 dropped 0 overruns 0 frame 0
    TX packets 119 bytes 5402 (5.2 KiB)
    TX errors 0 dropped 0 overruns 0 carrier 0 collisions 0

root@kali:~# nmap 192.168.105.55 | more
Starting Nmap 7.70 ( https://nmap.org ) at 2024-07-24 13:25 EDT
Nmap scan report for 192.168.105.55
Host is up (0.0020s latency).
All 1000 scanned ports on 192.168.105.55 are filtered
MAC Address: 00:15:5D:00:BA:06 (Microsoft)

Nmap done: 1 IP address (1 host up) scanned in 34.12 seconds
root@kali:~# nmap 192.168.105.55 | more
Starting Nmap 7.70 ( https://nmap.org ) at 2024-07-24 13:49 EDT
Nmap scan report for 192.168.105.55
Host is up (0.0027s latency).
Not shown: 995 filtered ports
PORT      STATE SERVICE
22/tcp    open  ssh
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
443/tcp   closed https
MAC Address: 00:15:5D:00:BA:06 (Microsoft)

Nmap done: 1 IP address (1 host up) scanned in 17.68 seconds
root@kali:~#
```

CONCLUSION

In this module, we learn to harden a Linux server by setting up a stateful firewall with iptables. Most enterprise organizations use applications that fall into two categories: Transmission Control Protocol (TCP) and User Datagram Protocol (UDP). UDP is a connectionless protocol, while TCP is a reliable, connection-oriented protocol.

SEC285

MODULE 4

BRING YOUR OWN DEVICE (BYOD)
SECURITY POLICY



Microsoft Word
Document

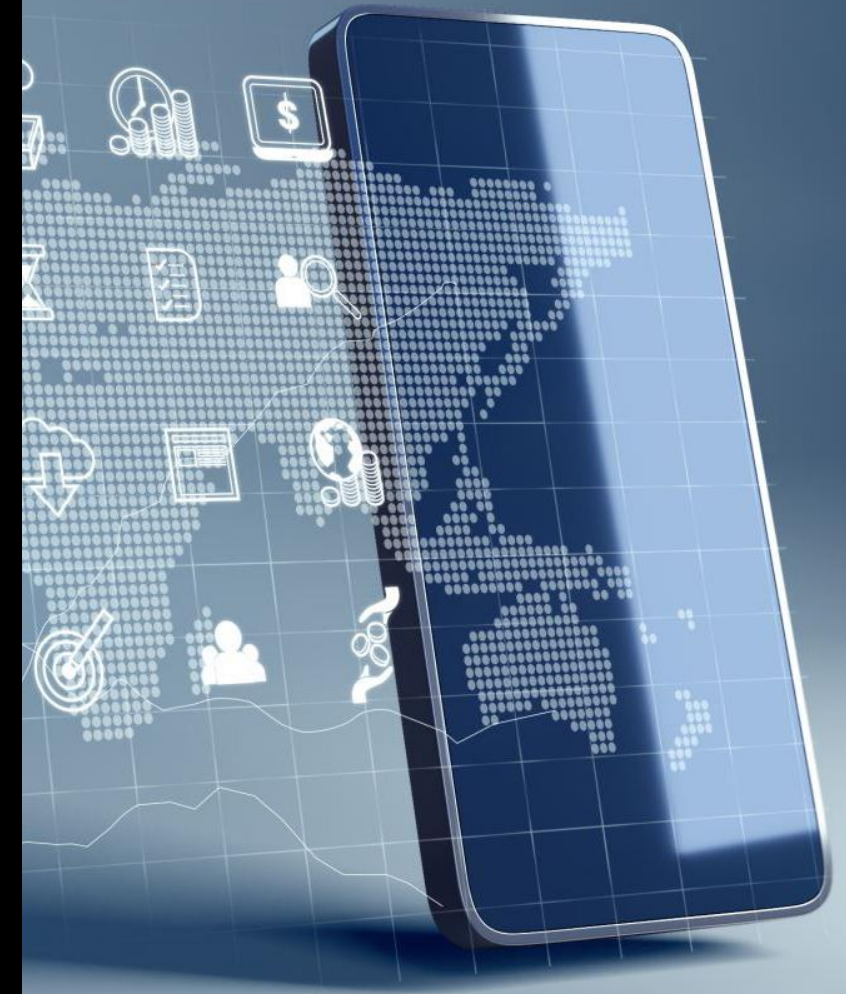
INTRODUCTION

In this module, we create the bring your own device (BYOD) security policy for ABC Corporation based on a SANS security policy template.

Overview: Tablets, smartphones, and laptops capture information, access, and update data. Threats associated with these devices include malware through spam, links, and rogue programs; unsecured Wi-Fi networks; network spoofing; and phishing attacks.

Purpose: An organization's computing resources can be compromised if vulnerabilities are not identified promptly. A vulnerability can be addressed more quickly if it is discovered early. As a result, attackers will have a smaller window of opportunity to exploit the vulnerability. Data breaches can be significantly reduced if vulnerabilities are discovered and patched promptly. A CIA helps protect data confidentiality, integrity, and availability. By identifying and resolving vulnerabilities promptly, an organization can demonstrate a commitment to security to customers and stakeholders.

Page 1



Scope: This policy applies to the following types of devices. ANY, any Computing device that can store and or process, transit/receive information when connected to the controlled network.

Policy: The company defines acceptable business use as activities that directly or indirectly support the business of the SANS Institute. Employees may use their BOYD devices for acceptable business and personal uses of the company computers as set out in the SANS Institute Computer Use Policy. Employees may use their mobile devices to access the following company-owned resources: Email/Callender/Contracts/Documents and anything related to SANS Institute.

Policy
Compliance:
Consequences
of Not Following
Security Policy

The consequences of not adhering to the security policy can vary depending on the severity of the violation and the specific policies of the organization. However, generally, the following steps may be taken:

Warning: The employee may first receive a warning, either verbal or written, informing them of their violation and the need to correct their behavior.

Training: If the violation is due to a lack of understanding or knowledge, the employee may be required to undergo additional training to ensure they understand the security policy.

Disciplinary Actions: More serious or repeated violations may result in disciplinary actions. These can range from a formal reprimand to suspension, depending on the severity of the violation.

Termination of Employment: In extreme cases, where the violation is severe or the employee repeatedly fails to adhere to the security policy, termination of employment may be the final step.

Related Standards, Policies, and Processes:

PCI-DSS is a set of security standards designed to ensure that all companies that accept, process, store or transmit credit card information maintain a secure environment. If your policy is related to financial transactions, e-commerce, or any industry that handles credit card information, it would be relevant to link to PCI-DSS. This is because PCI-DSS helps to prevent credit card fraud, hacking and various other security vulnerabilities and threats.

Other Relevant Documents

- **ISO 27001:** This is an international standard on how to manage information security. It details requirements for establishing, implementing, maintaining and continually improving an information security management system.
- **GDPR:** The General Data Protection Regulation is a regulation in EU law on data protection and privacy in the European Union and the European Economic Area. It also addresses the transfer of personal data outside the EU and EEA areas.
- **SOX:** The Sarbanes-Oxley Act is a law that sets enhanced standards for all U.S. public company boards, management, and public accounting firms.

Definitions and Terms:

BYOD - BYOD stands for bring your own device, and the most commonly accepted BYOD meaning is when employees use their own personal devices to connect to the organization's network and access what they need to do their jobs. This includes data and information that could be potentially sensitive or confidential.

CIA - The three letters in "CIA triad" stand for Confidentiality, Integrity, and Availability. The CIA triad is a common model that forms the basis for the development of security systems.

Revision History:

Date of change	Responsible	Summary of change
August 2019	SANS policy team	Updated and converted to new format
August 2024	Barbara Espericueta	Updated and converted to new format

CONCLUSION

SECURITY POLICIES ARE HIGH-LEVEL STATEMENTS APPROVED BY SENIOR MANAGEMENT TO GUIDE THE BEHAVIOR OF PEOPLE WHO COME INTO CONTACT WITH ORGANIZATIONAL COMPUTING RESOURCES. A SECURITY POLICY IS A SET OF DOCUMENTS THAT CLARIFY AN ORGANIZATION'S EXPECTATIONS REGARDING THE PROPER USAGE OF THEIR COMPUTING RESOURCES. IT SPECIFIES WHICH BEHAVIORS ARE CONSIDERED ACCEPTABLE AND WHICH ARE NOT.

THERE ARE THREE CATEGORIES OF SECURITY POLICIES: PROGRAM POLICY, ISSUE-SPECIFIC POLICY, AND SYSTEM-SPECIFIC POLICY.

A PROGRAM POLICY SETS THE DIRECTION OF A SECURITY PROGRAM. IT ALLOCATES APPROPRIATE RESOURCES TO ENSURE THAT THE SECURITY PROGRAM IS EFFECTIVELY IMPLEMENTED. AN ISSUE-SPECIFIC POLICY FOCUSES ON SPECIFIC TECHNOLOGIES IMPLEMENTED IN AN ORGANIZATION, SUCH AS EMAIL AND VIRTUAL PRIVATE NETWORKS (VPNS). A SYSTEM-SPECIFIC POLICY DEALS WITH TECHNOLOGIES (SIMILAR TO AN ISSUE-SPECIFIC POLICY), AS WELL AS ADDRESSING SECURITY PERSONNEL AND CONFIGURATIONS OF THE SAID TECHNOLOGIES.

ALL SECURITY PRACTITIONERS MUST BECOME FAMILIAR WITH THE PROCESS OF CRAFTING AN EFFECTIVE SECURITY POLICY, AS OUTLINED IN THIS PROJECT MODULE. THERE ARE MANY SAMPLE SANS SECURITY POLICIES. READING THESE POLICIES HELPS YOU UNDERSTAND WHAT NEEDS TO BE INCLUDED IN EACH SECTION OF A SECURITY POLICY.

SEC285
MODULE 5
MULTIFACTOR
AUTHENTICATION
(MFA)

INTRODUCTION

In this module, we implement multifactor authentication (MFA) by adding a time-based one-time password (OTP) to the authentication process.

```
user1@Ubuntu-S: ~/Desktop
[Visual noise: a grid of black and white squares]

Your new secret key is: GWITQDYZS6AONLBKFLGFDITFYQ
Your verification code is 975713
Your emergency scratch codes are:
74505507
84531093
92406622
29684334
87898262

Do you want me to update your "/home/user1/.google_authenticator" file? (y/n)
```

```
GNU nano 4.8 /etc/pam.d/common-auth
#
# As of pam 1.0.1-6, this file is managed by pam-auth-update by default.
# To take advantage of this, it is recommended that you configure any
# local modules either before or after the default block, and use
# pam-auth-update to manage selection of other modules.  See
# pam-auth-update(8) for details.

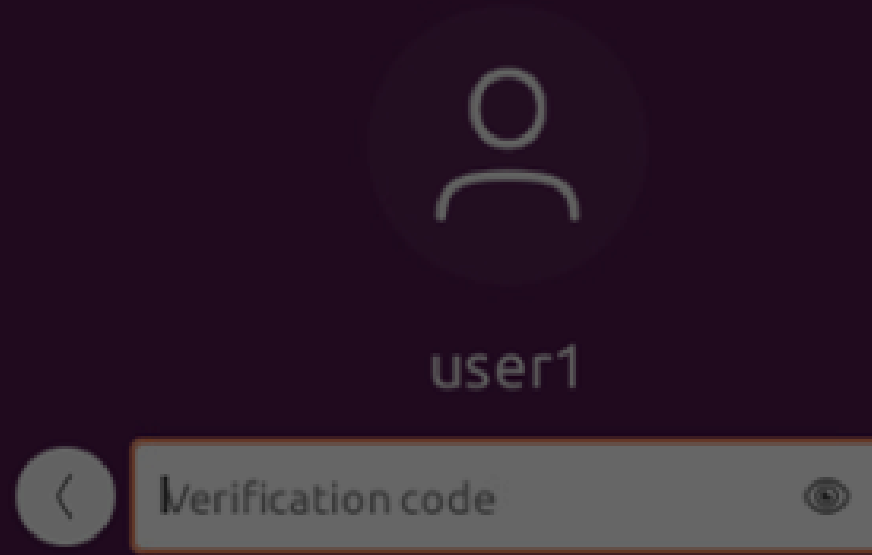
# here are the per-package modules (the "Primary" block)
auth [success=1 default=ignore] pam_unix.so nullok_secure
# here's the fallback if no module succeeds
auth requisite pam_deny.so
# prime the stack with a positive return value if there isn't one already;
# this avoids us returning an error just because nothing sets a success code
# since the modules above will each just jump around
auth required pam_permit.so
# and here are more per-package modules (the "Additional" block)
auth optional pam_cap.so
# end of pam-auth-update config
auth required pam_google_authenticator.so nullok

[ Wrote 28 lines ]

^G Get Help ^O Write Out ^W Where Is ^K Cut Text ^J Justify ^C Cur Pos
^X Exit ^R Read File ^\ Replace ^U Paste Text ^T To Spell ^_ Go To Line
```

COMMON-AUTH CONFIGURATION FILE

This screenshot shows the entry that indicates the use of the Google Authenticator module.



MFA LOGON SCREEN

This screenshot shows the logon screen where a verification code is required.

CONCLUSION

Many enterprises end users use a single password to access all computing resources. This is known as single sign-on (SSO). While this simplifies the authentication process for the end users, it also makes it easier for attackers to compromise the system. To mitigate this risk, multifactor authentication (MFA) uses a regular password and a time-based one-time password (OTP). In this module, the one-time password is generated using Google Authenticator app available on Android and iOS devices.

SEC285
MODULE 6
VULNERABILITY
ASSESSMENT

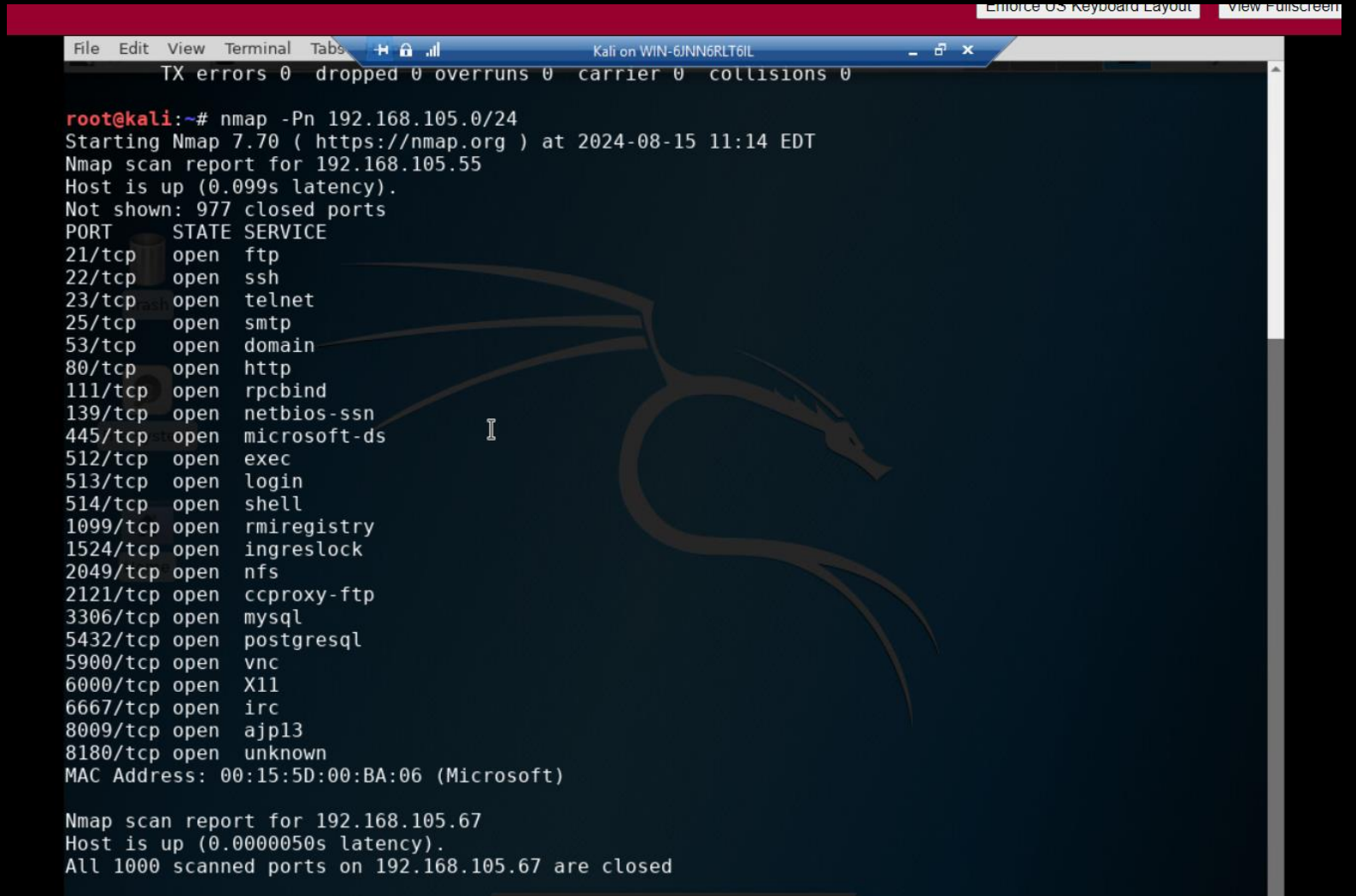
INTRODUCTION

In Module 6, we explore three vulnerabilities assessment tools.

NMAP

This screenshot includes the scan result showing both the Kali and Linux Server VMs.

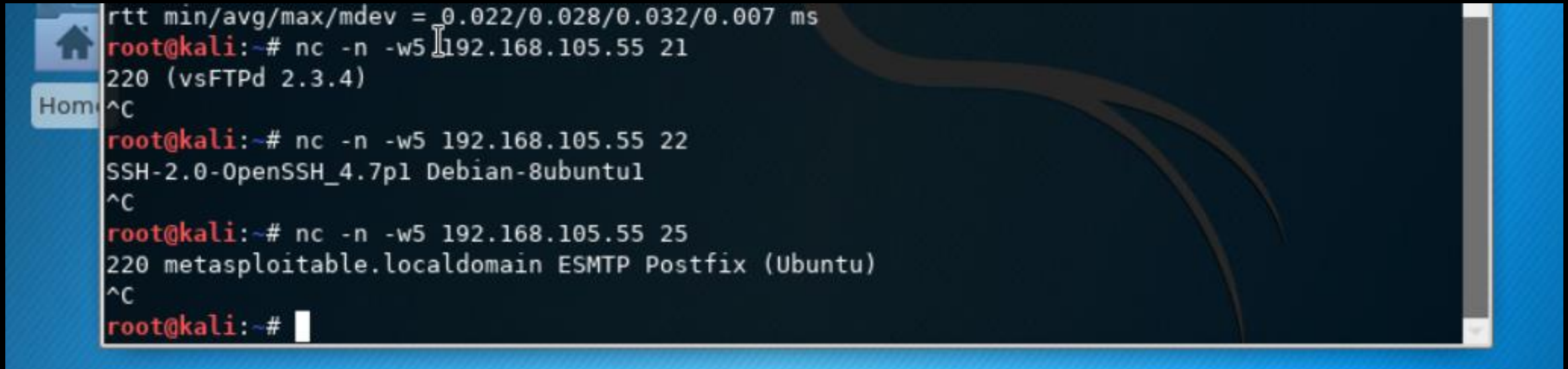
The NMAP tool can be used to identify IP addresses that are in use on a network segment, assuming that the hosts on the network segment are up and running.



```
root@kali:~# nmap -Pn 192.168.105.0/24
Starting Nmap 7.70 ( https://nmap.org ) at 2024-08-15 11:14 EDT
Nmap scan report for 192.168.105.55
Host is up (0.099s latency).
Not shown: 977 closed ports
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
23/tcp    open  telnet
25/tcp    open  smtp
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
445/tcp   open  microsoft-ds
512/tcp   open  exec
513/tcp   open  login
514/tcp   open  shell
1099/tcp  open  rmiregistry
1524/tcp  open  ingreslock
2049/tcp  open  nfs
2121/tcp  open  ccproxy-ftp
3306/tcp  open  mysql
5432/tcp  open  postgresql
5900/tcp  open  vnc
6000/tcp  open  X11
6667/tcp  open  irc
8009/tcp  open  ajp13
8180/tcp  open  unknown
MAC Address: 00:15:5D:00:BA:06 (Microsoft)

Nmap scan report for 192.168.105.67
Host is up (0.0000050s latency).
All 1000 scanned ports on 192.168.105.67 are closed
```

NETCAT

A screenshot of a terminal window with a dark blue background and a light blue sidebar on the left. The sidebar contains a home icon and the text 'Home'. The terminal shows the output of a Netcat scan. At the top, it displays 'rtt min/avg/max/mdev = 0.022/0.028/0.032/0.007 ms'. Below this, three Netcat commands are shown, each followed by its output. The first command is 'nc -n -w5 192.168.105.55 21', which returns '220 (vsFTPd 2.3.4)'. The second command is 'nc -n -w5 192.168.105.55 22', which returns 'SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1'. The third command is 'nc -n -w5 192.168.105.55 25', which returns '220 metasploitable.localdomain ESMTPostfix (Ubuntu)'. Each output is preceded by '^C'. The prompt 'root@kali:~#' is visible at the end of each command line.

```
rtt min/avg/max/mdev = 0.022/0.028/0.032/0.007 ms
root@kali:~# nc -n -w5 192.168.105.55 21
220 (vsFTPd 2.3.4)
^C
root@kali:~# nc -n -w5 192.168.105.55 22
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
^C
root@kali:~# nc -n -w5 192.168.105.55 25
220 metasploitable.localdomain ESMTPostfix (Ubuntu)
^C
root@kali:~#
```

This screenshot includes the scan result showing both the Kali and Linux Server VMs. The Netcat tool can be used to gain information about FTP, SSH, and SMTP applications that are discovered in an NMAP scan (called banner grabbing). Knowing the version of an application running on the server can be a great help in the exploitation phase.

WIRESHARK

This screenshot includes the Wireshark—Follow TCP Stream window showing the Telnet username and password.

Wireshark is a packet sniffing tool. It can be used by security practitioners to analyze network traffic and gain insight into client and server applications.

Contact: `msfdev[at]metasploit.com`

Login with `msfadmin/msfadmin` to get started

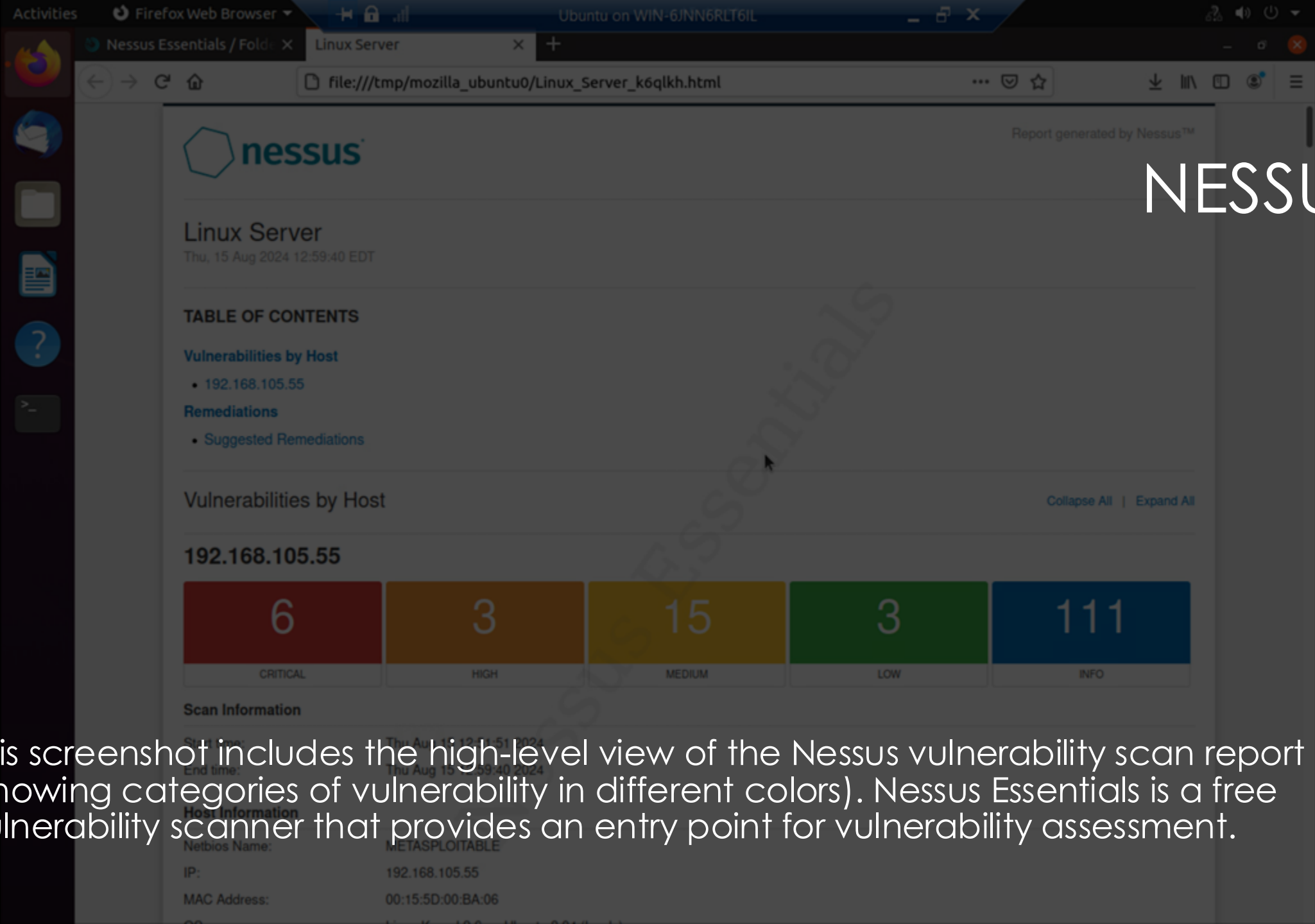
metasploitable login: `mmssffaaddmmiinn`

Password: `msfadmin`

Last login: Tue Aug 13 11:10:34 EDT 2024 on tty1

Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008

Packet 108. 22 *client* pkts, 19 *server* pkts, 27 turns. Click to select.



NESSUS

This screenshot includes the high-level view of the Nessus vulnerability scan report (showing categories of vulnerability in different colors). Nessus Essentials is a free vulnerability scanner that provides an entry point for vulnerability assessment.

CONCLUSION

To conduct a vulnerability assessment of a server in a testing or production environment, security practitioners use tools such as NMAP (the network mapper), Netcat, and Wireshark. We launched these tools on the Kali VM to assess the security posture of the Linux Server VM.

CHALLENGES/LESSONS LEARNED

Challenges faced while working on this project include Module, which dealt with the Bring Your Own Device (BOYD) Security Policy. The main challenges were ensuring the policy was organized-specific and protecting myself legally. I overcame these challenges by researching other BOYD policies and getting advice from instructors in tutoring. Lessons learned throughout this project highlighted the importance of encryption and decryption in Cyber Security.

CAREER SKILLS

Skills I developed during these projects include remediation, prioritization, communication, scanning, problem-solving, and asset directory. Competencies that will help me advance my career include the use of keys, one-way functions, and digital signatures. I became proficient in firewall technologies, developed and understanding of network concepts, became familiar with security protocols, and gained competence in operating systems. These skills will greatly benefit my career in Cyber Security.

CONCLUSION

Through these course projects, I developed skills in remediation, prioritization, communication, scanning, problem-solving, and asset directory. I also became proficient in firewall technologies, developed an understanding of network concepts, became familiar with security protocols, and gained competence in operating systems. Although facing challenges in some areas, they did not compare to all the skills gained; in reality, those challenges provided additional skills as well. Linux administrators employ various best practices to address security vulnerabilities, and performing those tasks gave me the confidence to learn more about Cyber Security.

Name _____

Signature _____

Date _____